

Impossible Travel — Multi-Agent Investigation Workflow

- [Overview](#)
 - [Detection Entry Point](#)
 - [Multi-Agent Workflow](#)
 - [Phase 1 — Context Agent](#)
 - [Phase 2 — Identity Agent \(Risk Factor Evaluation\)](#)
 - [Risk_LocationAnomaly](#)
 - [Risk_AuthenticationAnomaly](#)
 - [Risk_TokenAnomaly](#)
 - [Risk_BruteForcePattern](#)
 - [Risk_MfaAbuse](#)
 - [Risk_PostLoginSuspiciousActivity](#)
 - [Risk_OAuthAbuse](#)
 - [Risk_MailboxManipulation](#)
 - [Risk_HighPrivilegeUser](#)
 - [Risk_DisabledAccountSignIn](#)
 - [Data Source Summary](#)
 - [ThreatDecisionRecord Example](#)
 - [ThreatDecisionPolicy](#)
 - [Verdict and Action Plan](#)
 - [Agent Responsibility Boundaries](#)
-

1. Overview

This document describes how the PACO-SOC multi-agent framework investigates an **impossible travel** incident under the `AccountCompromise` threat scenario. The investigation follows a **risk-based pattern**: rather than a monolithic playbook with complex branching logic, the framework decomposes the incident into independent risk factors, evaluates each one separately with supporting evidence, and feeds the results back to the PACO Orchestrator which reasons over all collected risk factors and evidence to produce the final verdict and action plan.

Key principles:

- Every risk factor in the `AccountCompromise` catalog is evaluated independently. There is no dependency between risk evaluations.
- The PACO Orchestrator is the sole decision-maker. It receives the `ThreatDecisionPolicy` as context and uses it to guide its reasoning — there is no separate decision engine or scoring algorithm.
- Correlation happens only at the end, when PACO reviews all active risk factors, their supporting `RiskEvidence`, and the policy's risk-to-action mappings.

2. Detection Entry Point

An impossible travel incident enters the framework through a Sentinel Analytics Rule. Per the CORE Standard, the detection rule's only responsibility is to classify and emit a normalized signal — it does **not** enrich, investigate, or decide.

Normalized Detection Output

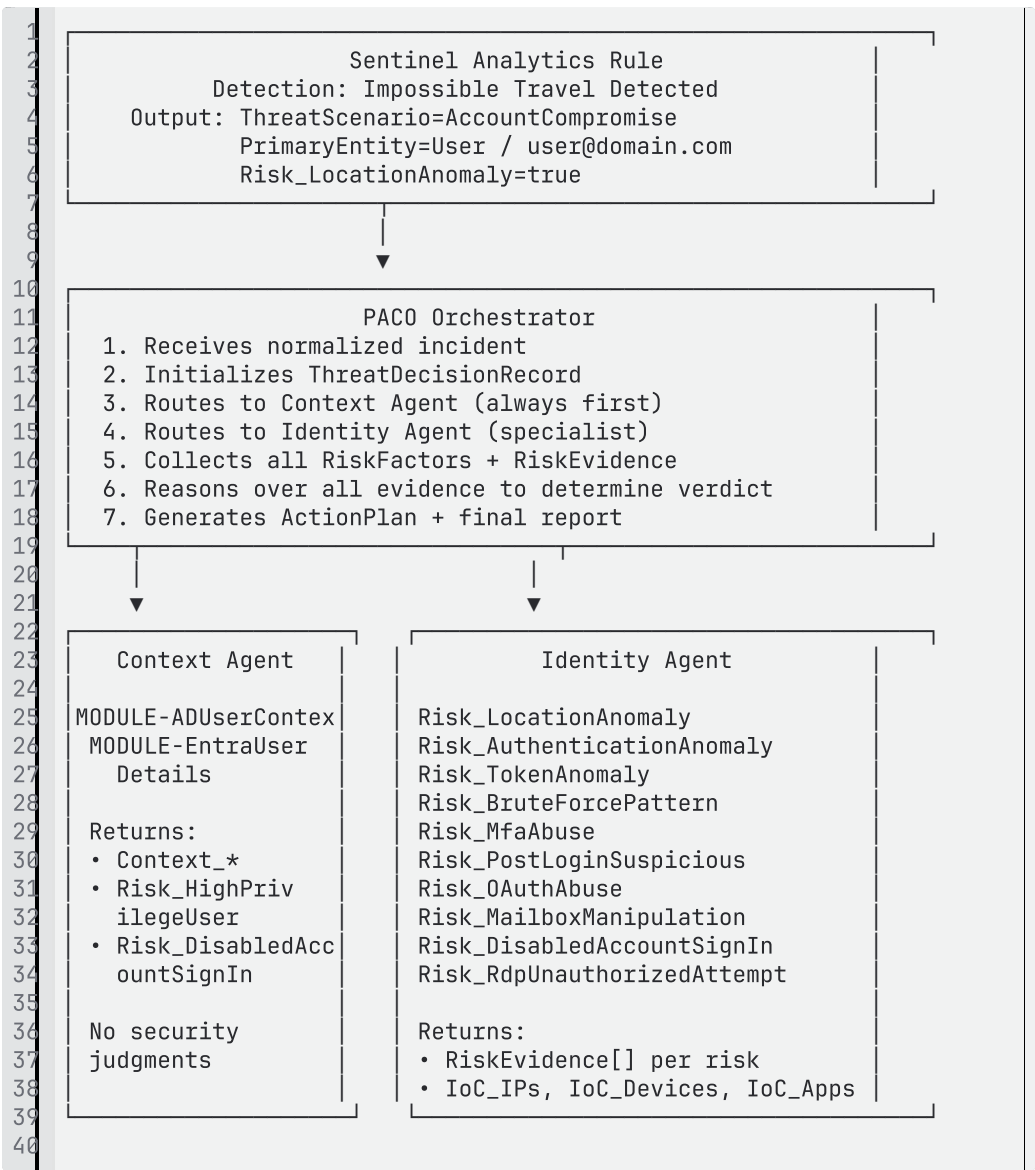
Field	Value	Source
<code>ThreatScenario</code>	<code>AccountCompromise</code>	Detection rule (from Threat Scenario Catalog)
<code>PrimaryEntityType</code>	<code>User</code>	Detection rule
<code>PrimaryEntityId</code>	<code>user@domain.com</code>	Detection rule (UPN)
<code>Risk_LocationAnomaly</code>	<code>true</code>	Detection rule (initial classification)

The detection may also emit initial IoCs extracted from the alert:

Field	Value
<code>IoC_IPs</code>	<code>["203.0.113.50", "198.51.100.22"]</code>

Standard rule 6: Detection rules must export detection information only; they must not perform enrichment or investigation.

3. Multi-Agent Workflow



PACO performs **step 6** itself — it reviews all risk factors, weighs the supporting evidence, and uses its reasoning guided by the `ThreatDecisionPolicy` to determine the final verdict, confidence, and action plan.

4. Phase 1 — Context Agent

The Context Agent is **always called first**. Its role is to enrich the primary entity with organizational and identity context. It produces `Context_*` fields and may activate identity-sensitivity risk factors, but it does **not** make security judgments.

Tools Called

MCP Tool	Data Source	Purpose
----------	-------------	---------

MODULE - ADUserContext	Active Directory (via Sentinel)	Department, manager, job title, country, office
MODULE - EntraUserDetails	Entra ID / Identity Protection	Account status, MFA registration, last sign-in, risk state, licenses

Outputs to ThreatDecisionRecord

Field	Example	Notes
Context_Department	"Finance"	Organizational context
Context_JobTitle	"CFO"	Travel likelihood assessment
Context_Country	"Netherlands"	Home-country baseline
Context_Manager	"ciso@domain.com"	Escalation contact
Context_MfaRegistered	"true"	MFA posture flag
Context_AccountEnabled	"true"	Account state
Context_RiskState	"atRisk"	Entra ID Protection risk state
Risk_HighPrivilegeUser	true	Set if user holds privileged role
Risk_DisabledAccountSignIn	false	Set if account is disabled but sign-in occurred

i If `Context_MfaRegistered = false`, this is flagged prominently — it changes the risk profile of every subsequent finding.

5. Phase 2 — Identity Agent (Risk Factor Evaluation)

The Identity Agent evaluates each applicable `AccountCompromise` risk factor independently. For impossible travel, the following risk factors from the catalog are in scope:

5.1 `Risk_LocationAnomaly` — Geographic Velocity Analysis

"Geographical inconsistency or impossible travel detected."

Objective: Confirm or dismiss the impossible travel signal by validating geographic velocity and source IP infrastructure.

Investigation Steps:

Step	MCP Tool	Data Source / Table	What to Extract
1	<code>MODULE-ASimAuthentication</code>	<code>imAuthentication</code> → <code>SignInLogs</code> , <code>AADNonInteractiveUserSignInLogs</code>	Timestamps, geo coordinates (lat/long), cities, countries, IPs for all sign-ins in the time window
2	<code>MODULE-ASimAuthentication-SourceAnalysis</code> (per IP)	<code>imAuthentication</code> + TI enrichment	ASN, ISP, geo-location, VPN/Tor/hosting classification, reputation score

Evidence Evaluation:

- Calculate distance between sign-in locations and time delta
- If velocity > 900 km/h and neither IP is VPN/Tor → strong evidence
- If one IP resolves to known VPN/cloud hosting ASN → may be benign (user on corporate VPN)
- Check `AADNonInteractiveUserSignInLogs` for token refreshes that reveal the true session location

RiskEvidence Example:

```
1 {  
2   "RiskFactor": "Risk_LocationAnomaly",
```

```

3  "Type": "GeoVelocity",
4  "Value": "Amsterdam→Singapore in 47min (17,200km – 21,957km/h)",
5  "Reason": "Travel speed exceeds physical possibility. Source IP
203.0.113.50 (AS14061, DigitalOcean) is cloud hosting infrastructure.",
6  "EvidenceScore": 95
7  }
8

```

5.2 Risk_AuthenticationAnomaly — Sign-In Pattern Analysis

i "Sign-in activity classified as anomalous."

Objective: Determine if the authentication characteristics of the anomalous sign-in deviate from the user's baseline.

Investigation Steps:

Step	MCP Tool	Data Source / Table	What to Extract
1	MODULE - ASimAuthenti cation	imAuthentica tion → SigninLogs	Auth method used, Conditional Access result, client app type, user agent
2	MODULE - ASimAuditEve nt	imAuditEvent → AuditLogs	Recent MFA registration changes, password resets, auth method modifications
3	MODULE - EntraUserDet ails	Entra ID	Current auth methods enrolled, risk state

Evidence Evaluation:

- Did the anomalous sign-in use a different auth method than the user's baseline?
- Was MFA satisfied, bypassed, or not required?

- Was a new auth method registered shortly before the anomalous sign-in?
- Was legacy authentication (IMAP, SMTP, POP3) used?
- Was Conditional Access evaluated and did it pass or fail?
- Device posture: is the device managed (`isManaged`), compliant (`isCompliant`), registered (`deviceId`)?

RiskEvidence Example:

```

1 {
2   "RiskFactor": "Risk_AuthenticationAnomaly",
3   "Type": "AuthMethod",
4   "Value": "Anomalous sign-in used password-only from unmanaged device
(deviceId empty); baseline is MFA + managed device",
5   "Reason": "Authentication downgrade from managed+MFA to
unmanaged+password-only. Device not enrolled in Intune (no EDR
coverage).",
6   "EvidenceScore": 85
7 }
8

```

5.3 Risk_TokenAnomaly — Concurrent Session Detection

 "Session hijack or token replay behavior detected."

Objective: Determine if sessions are active from both locations simultaneously, indicating token theft rather than legitimate travel.

Investigation Steps:

Step	MCP Tool	Data Source / Table	What to Extract
1		AADRiskyUser Events	

RiskEvidence Example:

```

1 {
2   "RiskFactor": "Risk_TokenAnomaly",
3   "Type": "ConcurrentSession",
4   "Value": "Outlook accessed from 198.51.100.22 (Amsterdam) and
203.0.113.50 (Singapore) within 3-minute window",
5   "Reason": "Simultaneous active sessions from geographically distant
locations confirm token theft or credential sharing.",
6   "EvidenceScore": 95
7 }
8

```

"Password spray or brute-force pattern detected."

Objective: Determine if the anomalous sign-in was preceded by brute-force or password-spray attempts.

Investigation Steps:

Step	MCP Tool	Data Source / Table	What to Extract
1	MODULE-ASimAuthentication-FailedSignIns	imAuthentication → SigninLogs (ResultType ≠ 0)	Aggregated failed attempts by IP, time, error code
2	MODULE-ASimAlertEvent	imAlertEvent → SecurityAlert	Existing Sentinel alerts for password spray or brute force
3	MODULE-ASimAuthentication-SourceAnalysis	Per-IP analysis	Whether the attacking IP has been seen in failures across multiple accounts

Evidence Evaluation:

- Multiple failed sign-ins from the anomalous IP followed by a success?
- Same IP appearing in failed sign-ins for other users (spray pattern)?
- Time pattern: rapid sequential failures indicating automated tooling?

RiskEvidence Example:

```
1 {
2   "RiskFactor": "Risk_BruteForcePattern",
3   "Type": "FailedAuthPattern",
4   "Value": "14 failed sign-ins from 203.0.113.50 in 8 minutes, then
5   "Reason": "Classic brute-force pattern: rapid sequential failures
   followed by success from the same IP.",
```



```
6   "EvidenceScore": 90
7 }
8
```

5.5 Risk_MfaAbuse — MFA Fatigue or Bypass

 "MFA fatigue or prompt-abuse pattern detected."

Objective: Determine if MFA was abused, fatigued, or modified to enable the anomalous sign-in.

Investigation Steps:

Step	MCP Tool	Data Source / Table	What to Extract
1	MODULE - ASimAuditEvent	imAuditEvent → AuditLogs	MFA method registrations/modifications, "User registered security info", "User deleted security info"
2	MODULE - ASimAuthentication	imAuthentication → SigninLogs	Multiple MFA prompts (MFA denied events followed by MFA success)
3	MODULE - EntraUserDetails	Entra ID	Current MFA methods registered, changes in registration

Evidence Evaluation:

- Were MFA methods changed in the hours before the anomalous sign-in?
- Multiple consecutive MFA denials followed by an approval (fatigue)?
- Was a new phone number or authenticator app registered by a different IP?
- Was MFA not required due to Conditional Access gap?

RiskEvidence Example:

```
1 {
2   "RiskFactor": "Risk_MfaAbuse",
3   "Type": "MfaModification",
4   "Value": "New phone number registered for MFA 2 hours before
5   anomalous sign-in, initiated from IP 203.0.113.50",
6   "Reason": "MFA method modification from the same anomalous IP shortly
7   before successful authentication – indicates attacker-controlled MFA
8   registration.",
9   "EvidenceScore": 95
10 }
```

5.6 Risk_PostLoginSuspiciousActivity — Post-Compromise Actions

 "Suspicious activity observed after successful login."

Objective: Determine if the anomalous sign-in was followed by actions consistent with account takeover.

Investigation Steps:

Step	MCP Tool	Data Source / Table	What to Extract
1	MODULE-ASimAuditEvent	imAuditEvent → AuditLogs	Password resets, role assignments, app consent grants, mail forwarding rules created
2	MODULE-ASimAuthentication-AppAccess	imAuthentication (per-app)	Access to sensitive apps (Azure Portal, Exchange Admin, SharePoint Admin) from anomalous IP
3	MODULE-ASimWebSession	imWebSession	Large data transfers,

	on		unusual URLs, bulk downloads
4	MODULE- ASimFileEven t	imFileEvent	File access/downloa d staging patterns

Evidence Evaluation:

- Password reset initiated from the anomalous IP?
- Inbox forwarding rule created to external address?
- Privileged role self-assignment?
- OAuth app consent grants?
- Bulk file downloads or email exports?
- Access to admin portals not in user's baseline?

RiskEvidence Example:

```
1 {  
2   "RiskFactor": "Risk_PostLoginSuspiciousActivity",  
3   "Type": "PersistenceMechanism",  
4   "Value": "Inbox rule 'Auto-Forward' created, forwarding all mail to  
external@attacker.com from IP 203.0.113.50",  
5   "Reason": "Mail forwarding rule created from the anomalous IP  
immediately after successful authentication – classic persistence  
technique for account takeover.",  
6   "EvidenceScore": 90  
7 }  
8
```

5.7 Risk_OAuthAbuse — Application Consent Abuse (Conditional)

 "Suspicious application consent or OAuth abuse detected."

Evaluated only if MODULE-ASimAuditEvent reveals consent grants or app registrations during the post-login window.

Step	MCP Tool	Data Source / Table	What to Extract
1	MODULE- ASimAuditEve nt	imAuditEvent → AuditLogs	"Consent to application"

			events, OAuth app registrations
2	MODULE-ASimAuthentication-AppAccess	imAuthentication	New app IDs not previously seen for this user

5.8 Risk_MailboxManipulation — Inbox Rule Abuse (Conditional)

 "Inbox-rule abuse or suspicious forwarding behavior detected."

Evaluated only if post-login audit events or OfficeActivity reveal inbox rule creation.

Step	MCP Tool	Data Source / Table	What to Extract
1	MODULE-ASimAuditEvent	imAuditEvent → AuditLogs	Inbox rule creation/modification
2	MODULE-ASimWebSession	imWebSession	OWA activity from anomalous IP

5.9 Risk_HighPrivilegeUser — Identity Sensitivity (From Context Agent)

 "The affected user has a privileged role."

This risk factor is set by the **Context Agent** based on the user's role in Entra ID. It is not investigated — it is an **amplifier** that increases the severity assessment PACO applies to all other active risk factors.

5.10 Risk_DisabledAccountSignIn — Disabled Account Check (From Context Agent)

 "Sign-in activity involving a disabled account was detected."

Set by the Context Agent if `MODULE-EntraUserDetails` returns `accountEnabled = false` while sign-in activity exists.

6. Data Source Summary

Primary Tables (Always Queried)

Sentinel Table	ASIM Normalized	MCP Tool	Risks Served
SigninLogs	imAuthentication	MODULE-ASimAuthentication	LocationAnomaly, AuthenticationAnomaly, TokenAnomaly, BruteForcePattern, MfaAbuse, PostLoginSuspiciousActivity
AADNonInteractiveUserSignInLogs	imAuthentication	MODULE-ASimAuthentication	TokenAnomaly (concurrent sessions)
AuditLogs	imAuditEvent	MODULE-ASimAuditEvent	AuthenticationAnomaly, MfaAbuse, PostLoginSuspiciousActivity, OAuthAbuse, MailboxManipulation
SecurityAlert	imAlertEvent	MODULE-ASimAlertEvent	BruteForcePattern (correlated alerts)
Entra ID (API)	—	MODULE-EntraUserDetails	AuthenticationAnomaly, MfaAbuse,

			HighPrivilegeUser, DisabledAccount SignIn
Active Directory	—	MODULE- ADUserContext	Context enrichment

Drill-Down Tables (Conditional)

Sentinel Table	ASIM Normalized	MCP Tool	Triggered When
SigninLogs (failed)	imAuthentication	MODULE- ASimAuthentication- FailedSignIns	Failed sign-ins detected
SigninLogs (per-IP)	imAuthentication	MODULE- ASimAuthentication- SourceAnalysis	Every distinct source IP (mandatory)
SigninLogs (per-app)	imAuthentication	MODULE- ASimAuthentication- AppAccess	Suspicious app access patterns
SigninLogs (timeline)	imAuthentication	MODULE- ASimAuthentication- UserLogon	Token reuse / session hijack suspected
Proxy / web logs	imWebSession	MODULE- ASimWebSession	Data exfiltration suspected

File activity	imFileEvent	MODULE-ASimFileEvent	File staging / download patterns
DNS logs	imDns	MODULE-ASimDNS	C2 / malware indicators

Data Source Prerequisites

Requirement	Connector	Impact if Missing
Must have	Entra ID Diagnostic Settings → SigninLogs + AuditLogs	Cannot investigate — core data
Must have	Entra ID Diagnostic Settings → AADNonInteractiveUserSignInLogs	Cannot detect concurrent sessions (TokenAnomaly)
Must have	Entra ID Identity Protection → risk events	Cannot check Entra risk state
Should have	Threat Intelligence connector	Degrades IP reputation analysis (LocationAnomaly)
Should have	M365 connector → OfficeActivity	Cannot detect mailbox manipulation
Nice to have	Sentinel UEBA → BehaviorAnalytics + IdentityInfo	Loses behavioral baseline for anomaly scoring

7. ThreatDecisionRecord — Impossible Travel Example

```

1 {
2   "ThreatScenario": "AccountCompromise",
3   "PrimaryEntity": {
4     "Type": "User",

```

```

5     "Id": "user@domain.com"
6 },
7 "RiskFactors": {
8     "Risk_LocationAnomaly": true,
9     "Risk_AuthenticationAnomaly": true,
10    "Risk_TokenAnomaly": true,
11    "Risk_BruteForcePattern": false,
12    "Risk_MfaAbuse": true,
13    "Risk_PostLoginSuspiciousActivity": true,
14    "Risk_OAuthAbuse": false,
15    "Risk_MailboxManipulation": true,
16    "Risk_HighPrivilegeUser": true,
17    "Risk_DisabledAccountSignIn": false,
18    "Risk_RdpUnauthorizedAttempt": false
19 },
20 "RiskEvidence": [
21     {
22         "RiskFactor": "Risk_LocationAnomaly",
23         "Type": "GeoVelocity",
24         "Value": "Amsterdam→Singapore in 47min (17,200km)",
25         "Reason": "Source IP 203.0.113.50 is DigitalOcean hosting
26         (AS14061). Travel speed physically impossible.",
27         "EvidenceScore": 95
28     },
29     {
30         "RiskFactor": "Risk_AuthenticationAnomaly",
31         "Type": "DevicePosture",
32         "Value": "Anomalous sign-in from unregistered device, password-
33         only auth",
34         "Reason": "Baseline is managed device with MFA. Anomalous sign-
35         in used password-only from device with no deviceId (not enrolled, no
36         EDR).",
37         "EvidenceScore": 85
38     },
39     {
40         "RiskFactor": "Risk_TokenAnomaly",
41         "Type": "ConcurrentSession",
42         "Value": "Outlook accessed from both IPs within 3-minute
43         window",
44         "Reason": "Non-interactive token refreshes from legitimate IP
45         while interactive sign-in from anomalous IP.",
46         "EvidenceScore": 95
47     },
48     {
49         "RiskFactor": "Risk_MfaAbuse",
50         "Type": "MfaModification",
51         "Value": "New phone registered for MFA 2h before anomalous sign-
52         in",
53         "Reason": "MFA method change initiated from anomalous IP prior
54         to successful authentication.",
55         "EvidenceScore": 95
56     },
57     {
58         "RiskFactor": "Risk_PostLoginSuspiciousActivity",
59         "Type": "PersistenceMechanism",
60         "Value": "Inbox forwarding rule to external@attacker.com",
61         "Reason": "Created from anomalous IP 8 minutes after successful
62         sign-in.",
63         "EvidenceScore": 90
64     },
65     {
66         "RiskFactor": "Risk_MailboxManipulation",
67         "Type": "InboxRule",
68         "Value": "Rule 'Auto-Forward' forwarding all inbound mail",
69         "Reason": "Forwarding to external address from anomalous
70         session.",
71         "EvidenceScore": 90

```



```

62     },
63     {
64         "RiskFactor": "Risk_HighPrivilegeUser",
65         "Type": "RoleAssignment",
66         "Value": "User holds Global Administrator role",
67         "Reason": "Privileged role amplifies impact of all other risk
factors.",
68         "EvidenceScore": 100
69     }
70 ],
71 "IoCs": {
72     "IoC_IPs": ["203.0.113.50"],
73     "IoC_Devices": ["unknown-device-no-id"],
74     "IoC_Applications": [],
75     "IoC_Domains": ["attacker.com"]
76 },
77 "Context": {
78     "Context_Department": "Finance",
79     "Context_JobTitle": "CFO",
80     "Context_Country": "Netherlands",
81     "Context_Manager": "ciso@domain.com",
82     "Context_MfaRegistered": "true",
83     "Context_AccountEnabled": "true",
84     "Context_RiskState": "atRisk"
85 }
86 }
87

```

8. ThreatDecisionPolicy — AccountCompromise

The `ThreatDecisionPolicy` is provided to PACO as context. PACO uses it as guidance for understanding risk-to-action mappings and action constraints — it reasons over the policy rather than executing it algorithmically.

```

1  {
2      "ThreatScenario": "AccountCompromise",
3      "Description": "Policy governing account compromise scenarios
including impossible travel, credential theft, MFA abuse, and post-
compromise activity.",
4      "RiskModel": {
5          "RiskWeights": {
6              "Risk_LocationAnomaly": 15,
7              "Risk_AuthenticationAnomaly": 15,
8              "Risk_TokenAnomaly": 20,
9              "Risk_BruteForcePattern": 10,
10             "Risk_MfaAbuse": 20,
11             "Risk_PostLoginSuspiciousActivity": 15,
12             "Risk_OAuthAbuse": 10,
13             "Risk_MailboxManipulation": 10,
14             "Risk_HighPrivilegeUser": 10,
15             "Risk_DisabledAccountSignIn": 5,
16             "Risk_RdpUnauthorizedAttempt": 5
17         }
18     },
19     "EvidenceMultiplier": {
20         "Enabled": true,
21         "Rules": [
22             { "MinScore": 80, "Multiplier": 1.0 },
23             { "MinScore": 50, "Multiplier": 0.6 },
24             { "MinScore": 0, "Multiplier": 0.3 }
25         ],
26         "AggregationStrategy": "MAX"

```

```

27   },
28   "ActionModel": {
29     "RiskFactorActionMap": {
30       "Risk_LocationAnomaly": ["revokeUserSessions", "blockSourceIP"],
31       "Risk_AuthenticationAnomaly": ["revokeUserSessions",
"enforcePasswordReset"],
32       "Risk_TokenAnomaly": ["revokeUserSessions",
"enforcePasswordReset"],
33       "Risk_BruteForcePattern": ["blockSourceIP"],
34       "Risk_MfaAbuse": ["resetMfaMethods", "revokeUserSessions",
"enforcePasswordReset"],
35       "Risk_PostLoginSuspiciousActivity": ["disableUserAccount",
"revokeUserSessions"],
36       "Risk_OAuthAbuse": ["revokeOAuthConsent", "revokeUserSessions"],
37       "Risk_MailboxManipulation": ["removeInboxRules",
"revokeUserSessions"],
38       "Risk_HighPrivilegeUser": ["escalateToTier2"],
39       "Risk_DisabledAccountSignIn": ["disableUserAccount",
"revokeUserSessions"]
40     }
41   },
42   "ActionDefinitions": {
43     "revokeUserSessions": { "Destructive": false,
"ExecutionConstraints": [] },
44     "enforcePasswordReset": { "Destructive": false,
"ExecutionConstraints": [] },
45     "blockSourceIP": { "Destructive": false, "ExecutionConstraints":
[] },
46     "disableUserAccount": { "Destructive": true,
"ExecutionConstraints": ["Risk_HighPrivilegeUser"] },
47     "resetMfaMethods": { "Destructive": true, "ExecutionConstraints":
[] },
48     "revokeOAuthConsent": { "Destructive": true,
"ExecutionConstraints": [] },
49     "removeInboxRules": { "Destructive": false,
"ExecutionConstraints": [] },
50     "escalateToTier2": { "Destructive": false, "ExecutionConstraints":
[] }
51   },
52   "PolicyEngine": {
53     "AutoThreshold": 50,
54     "SemiThreshold": 25,
55     "RestrictedActions": ["disableUserAccount"]
56   }
57 }
58

```

9. Verdict and Action Plan

How PACO Concludes the Investigation

Once the Context Agent and Identity Agent have returned their findings, PACO holds the complete `ThreatDecisionRecord` with all active risk factors, their supporting `RiskEvidence`, IoCs, and context. PACO then reasons over this material to produce the final verdict.

PACO's conclusion follows this structure:

1. Risk Factor Review

PACO reviews each active risk factor and its supporting evidence. Risk factors without supporting evidence (set by detection but not confirmed by investigation) are noted as unconfirmed. Risk factors confirmed with high-confidence evidence are weighted more heavily in the assessment.

2. Correlation and Synthesis

PACO correlates findings across risk factors to identify attack patterns:

- Risk_LocationAnomaly + Risk_TokenAnomaly → confirms token theft (not just VPN usage)
- Risk_MfaAbuse + Risk_PostLoginSuspiciousActivity → confirms account takeover with persistence
- Risk_LocationAnomaly alone + user has travel history → likely benign

3. Verdict Determination

PACO assigns a verdict with confidence:

Pattern	Verdict	Confidence
Location anomaly + concurrent sessions from both IPs	Account Compromised	High
Location anomaly + MFA modification + post-login persistence	Account Compromised	High
Location anomaly + unmanaged device + brute force	Account Compromised	High
Location anomaly + weak auth + no travel history	Likely Compromised	Medium
Location anomaly + VPN IP + user has travel history	Benign — VPN usage	Medium

Location anomaly alone + known travel pattern	Benign — legitimate travel	High
---	---------------------------------------	------

4. Action Plan Generation

Based on the active risk factors and the verdict, PACO generates the `ActionPlan`. The `ThreatDecisionPolicy` provides PACO with the risk-to-action mappings and action properties (destructive, constraints), but PACO decides which actions to include based on its assessment of the evidence. For destructive actions affecting privileged users, PACO flags them for analyst approval rather than automatic execution.

Example — PACO's Final Output

Given the example record from section 7 (where `Risk_LocationAnomaly`, `Risk_AuthenticationAnomaly`, `Risk-TokenAnomaly`, `Risk_MfaAbuse`, `Risk_PostLoginSuspiciousActivity`, `Risk_MailboxManipulation`, and `Risk_HighPrivilegeUser` are all active with evidence scores ≥ 85):

Verdict: Account Compromised — High Confidence

Reasoning: The user signed in from Singapore (DigitalOcean hosting IP) while concurrent token refreshes continued from Amsterdam. MFA methods were modified from the attacker IP 2 hours prior, and a mail forwarding rule to an external address was created 8 minutes post-login. This pattern — infrastructure IP, concurrent sessions, MFA takeover, and persistence mechanism — confirms account compromise, not legitimate travel.

ActionPlan:

```

1 {
2   "actionPlan": [
3     { "action": "revokeUserSessions", "target": "User", "value":
4       "user@domain.com", "riskFactor": "Risk-TokenAnomaly" },
5     { "action": "blockSourceIP", "target": "IP", "value":
6       "203.0.113.50", "riskFactor": "Risk_LocationAnomaly" },
7     { "action": "enforcePasswordReset", "target": "User", "value":
8       "user@domain.com", "riskFactor": "Risk_AuthenticationAnomaly" },
9     { "action": "resetMfaMethods", "target": "User", "value":
10      "user@domain.com", "riskFactor": "Risk_MfaAbuse" },
11    { "action": "removeInboxRules", "target": "Mailbox", "value":
12      "user@domain.com", "riskFactor": "Risk_MailboxManipulation" },
13    { "action": "disableUserAccount", "target": "User", "value":
14      "user@domain.com", "riskFactor": "Risk_PostLoginSuspiciousActivity" },
15    { "action": "escalateToTier2", "target": "User", "value":
16      "user@domain.com", "riskFactor": "Risk_HighPrivilegeUser" }
17  ]
18 }

```

 **Note on destructive actions:** `disableUserAccount` is destructive and the user holds `Risk_HighPrivilegeUser`. PACO flags this for analyst confirmation rather than auto-executing.

10. Agent Responsibility Boundaries

Responsibility	Owner	Standard Rule
Classify incident, set <code>ThreatScenario</code> , emit initial <code>Risk_*</code> flags	Detection Rule	Rule 6: detection only, no enrichment
Enrich entity context (<code>Context_*</code>), flag <code>Risk_HighPrivilegeUser</code> , <code>Risk_DisabledAccountSignIn</code>	Context Agent	No security judgments
Evaluate all identity risk factors, produce <code>RiskEvidence[]</code> , collect IoCs	Identity Agent	Mandatory steps 1–6, independent per-risk evaluation
Review all risk factors + evidence, determine verdict, generate <code>ActionPlan</code>	PACO Orchestrator	Guided by <code>ThreatDecisionPolicy</code> as context, no separate engine

This document is aligned with the ThreatDecision Framework CORE Standard, the official Risk Factor Catalog (AccountCompromise), and the Threat Scenario Catalog.